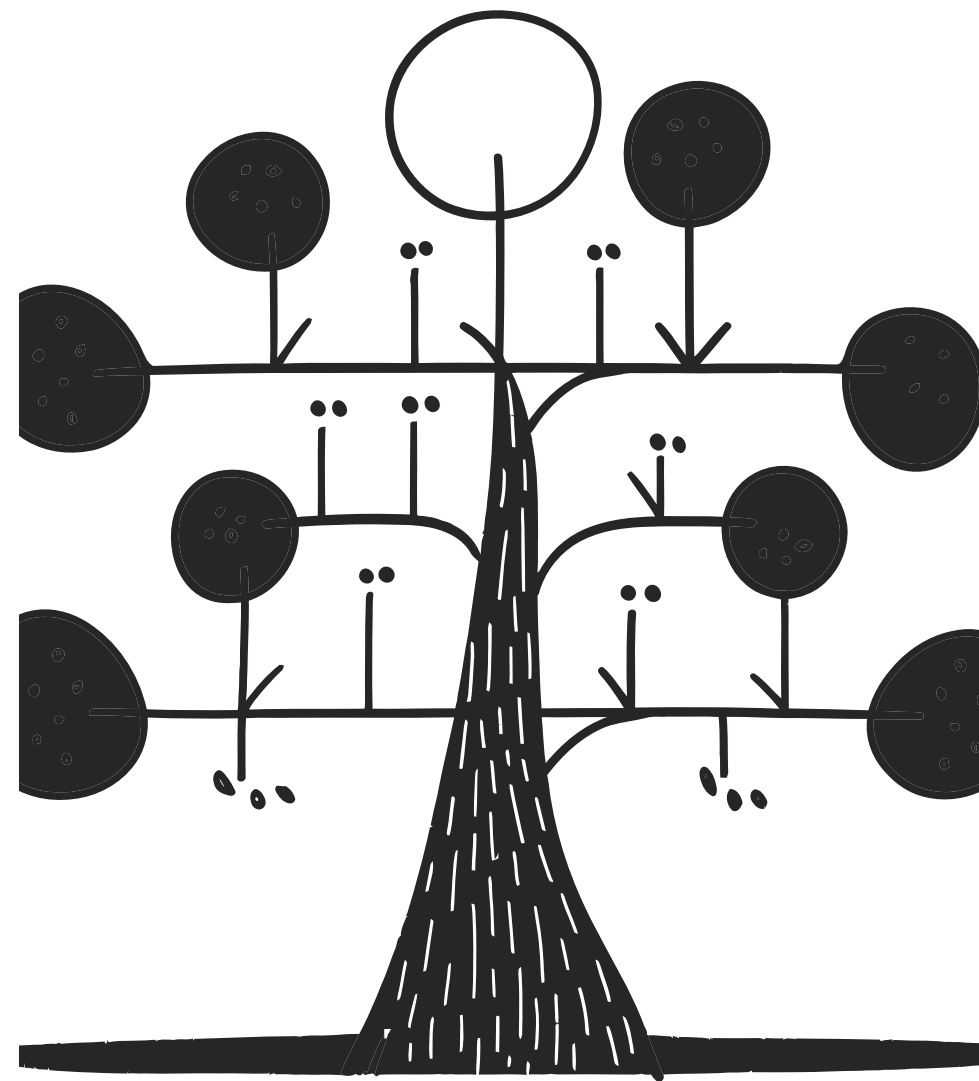


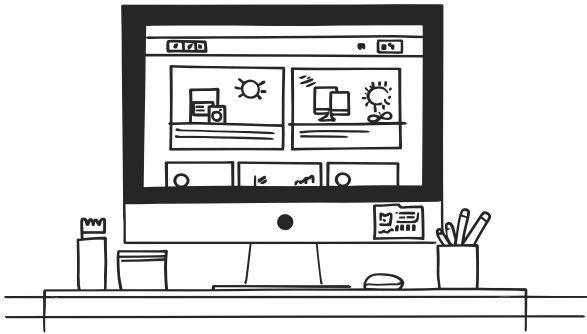
Teoria R2 — JSON, codis HTTP i autenticació mínima per a client

Com un backend PHP pot respondre JSON, usar codis HTTP i protegir una ruta amb un token simple.

CICLE FORMATIU · DAW



De pàgina web a resposta per a client



Dues maneres de respondre

Fins ara el backend retornava **HTML**: contingut dissenyat perquè una persona el llija al navegador.

Quan el client és un programa (DWECS, app mòbil...), necessita **dades estructurades**, no una pantalla.

- ❶ HTML és per a persones.
JSON és per a programes.

Què és JSON i com el retornem des de PHP

JSON és un format de text estructurat, fàcil de llegir i de parsejar per qualsevol llenguatge.

Capçalera obligatòria

```
header('Content-Type: application/json');
```

Content-Type

Indica al client que rebrà JSON, no HTML.

Resposta correcta

```
echo json_encode(['token' => $token]);
```

json_encode()

Converteix l'array PHP en text JSON vàlid.

Resposta d'error

```
http_response_code(401);  
echo json_encode(['error' => 'Credencials incorrectes']);
```

http_response_code()

Estableix el codi HTTP de la resposta.

El contracte de l'API

Una API mínima necessita un **contracte clar** perquè el client sàpiga exactament com comunicar-se.

Mètode

GET, POST, PUT, DELETE...

URL

Ruta exacta del recurs

Headers

Content-Type, Authorization...

Body

Dades enviades (JSON)

Codi HTTP

200, 201, 401, 403...

Exemple resposta

JSON esperat pel client

Codis HTTP: el llenguatge de l'estat

2xx Èxit

inclou 200 OK i 201 Created

4xx Error del client

inclou 400 Bad Request, 401
401 Unauthorized i 403 Forbidden

5xx Error del servidor

inclou 500 Internal
Server Error

Per què importa el codi?

El codi HTTP forma part de la resposta i és la primera informació que llegeix el client per saber si l'operació ha anat bé o malament.

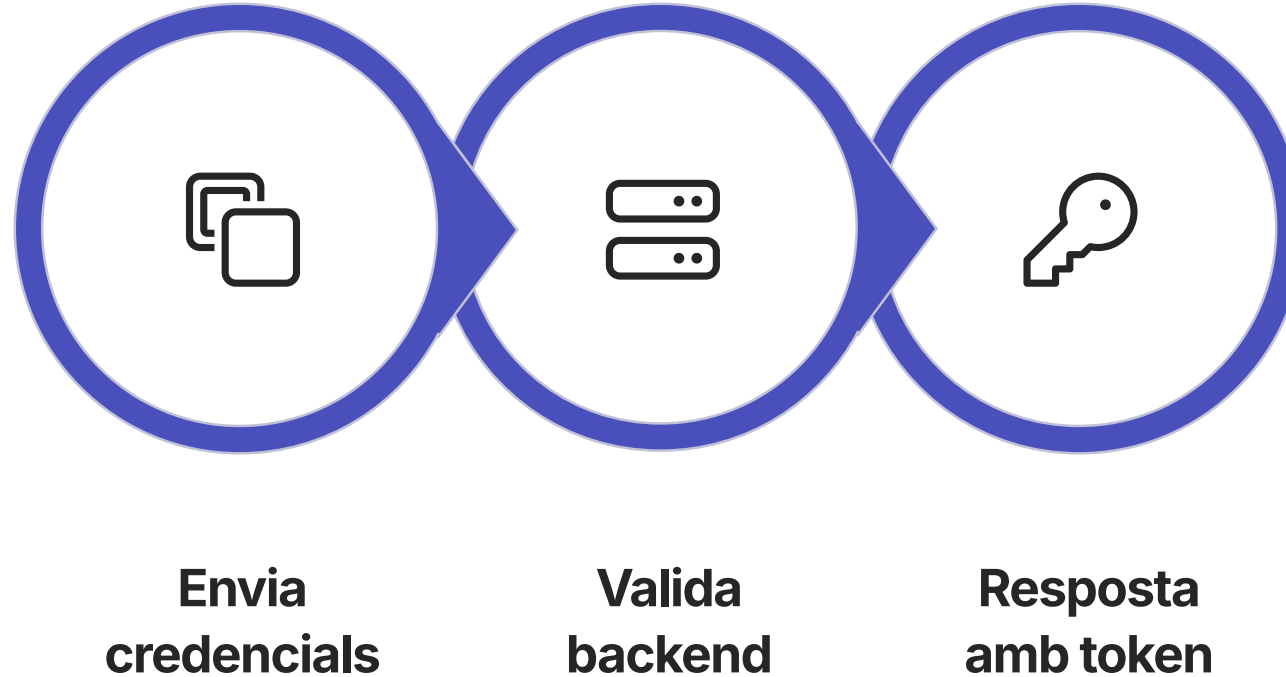


401 Unauthorized: no autenticat o credencial no vàlida. El client ha d'enviar credencials correctes.



403 Forbidden: autenticat però sense permís per a aquest recurs.

Login API: de credencials a token



El token és una prova temporal d'autenticació que el client guardarà i enviarà en cada petició posterior. **Mai no s'han de retornar contrasenyes ni hashes en la resposta.**

Ruta protegida: Authorization Bearer

El client envia el token

```
Authorization: Bearer el-meu-token-secret
```

El backend el llegeix

```
$auth = $_SERVER['HTTP_AUTHORIZATION'] ?? '';  
$token = str_starts_with($auth, 'Bearer ')  
    ? substr($auth, 7)  
    : '';
```

Comprova i respon

```
if ($token !== $tokenVàlid) {  
    http_response_code(401);  
    echo json_encode(['error' => 'Token no vàlid']);  
    exit;  
}  
echo json_encode(['dades' => $resultat]);
```

1 Client envia el header

Cada petició a una ruta protegida inclou el token al header `Authorization`.

2 Backend extreu el token

Llegeix `HTTP_AUTHORIZATION` i separa el prefix `Bearer`.

3 Valida i respon

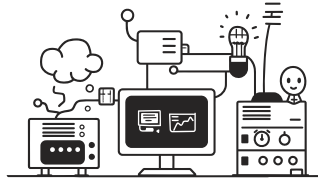
Si el token és vàlid retorna les dades; si no, retorna 401 sense exposar informació sensible.

Eines de prova: com verificar l'API



curl

Eina de línia d'ordres. Ideal per provar ràpidament peticions GET i POST amb headers personalitzats.



Postman / Insomnia

Aplicació gràfica. Permet guardar col·leccions de peticions i veure respostes formatades en JSON.



fetch (JavaScript)

Des del client DWEC. Permet enviar credencials i el token Bearer directament des del navegador.

- ❏ Sempre proveu el **cas correcte** (credencials bones, token vàlid) i el **cas incorrecte** (credencials errònies, token absent o invàlid).

Límits d'aquesta implementació

El que estem construint és un punt de partida didàctic, no un sistema de producció.

Què tenim

- Token simple generat al login
- Comprovació manual al backend
- Protecció bàsica de rutes

Què no tenim (encara)

- Refresh token
- OAuth 2.0 / OpenID
- Caducitat automàtica del token
- JWT signat

Objectiu

Entendre el contracte bàsic client-servidor per poder ampliar-ho a R4 amb estàndards complets.

Preguntes de repàs

01

HTML vs JSON

Quina diferència hi ha entre tornar HTML i tornar JSON des del backend?

02

Codis HTTP del login

Quin codi retorna el login correcte i quin retorna el cas incorrecte?

03

El contracte

Què ha de contindre el contracte perquè DWEC pugui consumir la mini API?

04

Validació del token

On es comprova el token: al client o al servidor?

05

Informació prohibida

Quina informació no ha d'aparèixer mai en la resposta JSON?